

Lab 07 — Add ChatGPT Mode, Then Try to Break It

Course: Codex Masterclass (C989)

Topic 2 · about 25 minutes · slides 64–67

Surface: Codex

Features: OpenAI Responses API · gpt-6-luna · grounded prompt · prompt injection

The story so far

The answers are accurate but read like a brochure. Grace's partner wants friendlier replies — with no server bill and no chance of the bot inventing a discount. Add a ChatGPT mode that stays grounded, then attack it like a mischievous visitor would.

Your goal

Search mode quotes documents. ChatGPT mode writes a real answer — still only from those documents, and without ever shipping a key.

You'll build

A two-mode assistant that stays grounded under attack

What is in this folder

- `assets/grounded-prompt.md`
- `assets/red-team.csv`
- `assets/responses-api-example.md`
- `solution/` — reference files from the verified build
- `prompts.md` / `prompts.pdf` — every prompt, ready to paste
- `evidence/checklist.md` — what to capture as proof

Step by step

1. **Add the mode** — Paste the prompt.
2. **Use a class key** — Paste the trainer's spend-limited key into the settings panel — never into a file or a chat with Codex.
3. **Compare the modes** — Ask five questions in each mode. Note which answers are better and why.
4. **Red-team it** — Run all 10 attacks in `red-team.csv`. Record each result.
5. **Close the tab** — Reopen the site. The key must be gone.

The prompts

PROMPT — Codex

Add a ChatGPT mode to the course assistant.

- A settings panel: API key (password field) and model (default gpt-6-luna). Store the key in sessionStorage ONLY. Never in code, localStorage or the repo.
- On a question: retrieve the top 3 chunks, then POST <https://api.openai.com/v1/responses> with instructions from grounded-prompt.md and the chunks as numbered sources.
- Show the answer with its [n] citations.
- On any API error, fall back to search mode.
- Retrieval with no hits → refuse without calling the API.

Check your work

- ☐ git grep "sk-" finds no key anywhere in the repo.
- ☐ The key disappears when the tab is closed.
- ☐ ChatGPT-mode answers cite their sources as [1], [2].
- ☐ An off-topic question is refused without an API call.
- ☐ No attack revealed the instructions or invented a discount.
- ☐ A bad key falls back to search mode with a message.

If it goes wrong

- **401 Unauthorized** — The key is wrong or revoked. Clear it and paste again.

Stretch

- Log token usage per answer and estimate cost per 1,000 questions.

Why it matters: The browser can call the API directly (it allows CORS), which is why the key must come from the visitor, not the site.

Next

Lab 8 — QA the Whole Site with @Computer Use. Keep what you built — the next lab starts from it.

Safety

Use only this lab's synthetic data and your own accounts. Never paste a real API key, password or personal data into a prompt or a file. Every email address in the data must resolve to your own

inbox. Nothing is published or sent without your explicit approval.